Enterprise DLP Assessment & Strategy — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Enterprise DLP Assessment & Strategy (Microsoft Purview) 4
- The problem . . . 4
- The solution . . . 4
- What it delivers . . . 4
- Business outcomes . . . 4
- Boundaries (so scope is clear) . . . 5

1. Solution Overview — Enterprise DLP Assessment & Strategy (Microsoft Purview) 5
- What this solution is . . . 5
- Why this matters . . . 6
- How it works . . . 6
- What "sensitive-data discovery" draws on (all Microsoft-native) . . . 7
- The assess→roadmap journey (the core discipline) . . . 7
- What you can control . . . 7
- Limitations (be honest with buyers) . . . 7
- Naming convention (used in every doc and script) . . . 8
- The standard deployment model . . . 8

2. Requirements — Enterprise DLP Assessment & Strategy (Microsoft Purview) 9
- 2.1 Licensing sufficient for the discovery surfaces you will use . . . 9
- 2.2 Assessment-specific least-privilege roles (read-heavy) . . . 9
- 2.3 Audit logging enabled and retaining data . . . 10
- 2.4 A defined classification intent and a data-category shortlist . . . 10
- 2.5 Approval to create ONE monitor-only simulation DLP policy . . . 10
- 2.6 An assessment scope, dwell time, and stakeholder sign-off path . . . 11

Global Requirements — Microsoft Purview Solutions 12
- 1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12
- 2. Purview roles (least-privilege) and portal access . . . 12
- 3. Security & Compliance PowerShell + Graph toolchain . . . 13
- 4. Data sources & scope in scope . . . 13
- 5. Compliance, records, privacy & legal stakeholders . . . 13
- 6. A pilot scope and change control . . . 14

3. Implementation Guide — Enterprise DLP Assessment & Strategy (Microsoft Purview) 14
- Phase 0 — Connect and baseline current posture (Assess) . . . 14
- Phase 1 — Discover where sensitive data RESTS (Assess — data at rest) . . . 15
- Phase 2 — Stand up the monitor-only SIMULATION baseline (Configure — no user impact) . . . 15
- Phase 3 — Measure how sensitive data MOVES (Pilot the discovery) . . . 16

Phase 4 — Rank exposure and build the roadmap (Design) . . . 16
Phase 5 — Review, ratify, and hand off (Expand) . . . 17
Order-of-operations summary . . . 18
5. Testing & Validation — Enterprise DLP Assessment & Strategy (Microsoft Purview) 18
Test A — Posture baseline (Assess) . . . 18
Test B — Sensitive-data discovery (rest + motion) . . . 19
Test C — Ranking & roadmap quality (Design) . . . 20
Test D — Non-enforcement & reversibility (safety) . . . 20
Evidence to capture (for the deliverable record) . . . 21
6. Troubleshooting — Enterprise DLP Assessment & Strategy (Microsoft Purview) 21
Discovery — data at rest (Content Explorer) . . . 21
Configuration — the monitor-only simulation baseline . . . 22
Discovery — data in motion (reporting) . . . 23
Ranking & roadmap . . . 23
Connectivity / tooling . . . 23
7. Best Practices — Enterprise DLP Assessment & Strategy (Microsoft Purview) 24
Discover before you design — always . . . 24
Keep the assessment non-enforcing and reversible . . . 25
Rank by exposure, not opinion . . . 25
Right-size the roadmap for an enforcement project . . . 25
Respect the discovery's licensing and privacy boundaries . . . 25
Hand off cleanly and stay inside the boundary . . . 26
8. Deliverables Summary — Enterprise DLP Assessment & Strategy (Microsoft Purview) 26
Documentation . . . 26
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 27
Definition of done . . . 28
Appendix A — PowerShell Scripts 29

Executive Summary — Enterprise DLP Assessment & Strategy (Microsoft Purview)

The problem

Data Loss Prevention projects fail in a predictable way: the team writes DLP policies before it knows what sensitive data the organization holds, where it lives, or how it moves — then switches those policies to enforce and floods the business with false positives until DLP is switched off. **DLP without a data map produces noise, not protection.** Left unaddressed, the result is both a compliance gap (no defensible view of sensitive-data exposure) and a data-risk exposure (leaks that no one can see).

The solution

Do the assessment **before** the enforcement. This solution delivers, in **Microsoft Purview**, a **DLP posture assessment**, a **sensitive-data discovery** exercise, and a **prioritized DLP rollout strategy** — using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. It baselines what DLP exists today, uses **Content Explorer** to map where sensitive data **rests** across Exchange, SharePoint, OneDrive, and Teams, stands up **one monitor-only DLP policy in SIMULATION mode** (Microsoft's built-in test mode — zero user impact) to measure how sensitive data **moves**, then ranks data categories by real **exposure** and produces a **simulation-first, ringed rollout roadmap**. Crucially, it **enforces nothing**: the only Purview object created is a simulation policy that can be deleted in one step.

What it delivers

- A **DLP posture baseline** — every existing policy, its mode, and the sensitive-information-type and label

coverage in the tenant.

- A **sensitive-data map** — where each candidate data category rests (Content Explorer) and how much of it

moves and is shared externally (simulation baseline + Activity Explorer), reconciled.

- A **ranked exposure view** — data categories prioritized by prevalence, external-sharing exposure, and

movement volume, with the weighting recorded.

- A **prioritized DLP rollout roadmap** — for each category: the detector, the location, the action

progression (audit → tip → justify → block), the pilot ring, and the order — every step simulation-first, gated, and reversible, with detector gaps captured as a build backlog.

- **Five PowerShell tools** (posture baseline, Content Explorer data scan, readiness/non-enforcement

validation, simulation-baseline helper, exposure/movement report) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

- **Know what to protect before writing a policy** — priorities set by measured exposure, not guesswork, so

the eventual enforcement project targets the real risk first.

- **Zero business disruption during the assessment** — the only policy created is in simulation; no user is

ever blocked or tipped, and it is instantly removable.

- **A defensible compliance position** — a documented posture, a sensitive-data map, and a ratified roadmap,

instead of an empty DLP blade.

- **A de-risked enforcement project** — the data map, movement report, ranked exposure, detector backlog,

and simulation-first roadmap are the complete input to a DLP enforcement engagement.

- **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and

tooled to run in-house.

Boundaries (so scope is clear)

Discovery depth is **licensing-/plan-dependent** — Content Explorer, Activity Explorer, on-demand classification, trainable classifiers, and DSPM require **E5 / E5 Compliance** and some are in **preview** (verify your tenant). This solution provides the **assessment, the discovery evidence, and the recommended roadmap**; *which* data categories are ultimately in scope, *which* classifiers legally apply, and the **enforced action per category** are **compliance, privacy, and legal determinations**, ratified alongside the delivered evidence. The assessment feeds an enforcement project — it is not itself an enforced control.

1. Solution Overview — Enterprise DLP Assessment & Strategy (Microsoft Purview)

What this solution is

Most Data Loss Prevention projects fail at the same point: a team writes DLP policies before they know **what** sensitive data they hold, **where** it lives, or **how** it moves — then switches those policies to enforce and drowns the business in false positives. This solution inverts that order. It delivers a **DLP posture assessment**, a **sensitive-data discovery** exercise, and a **prioritized DLP rollout strategy** in **Microsoft Purview** — so you know exactly what to protect, in what order, and with what policy, **before** you write a single enforcing rule.

It uses only the **Microsoft Purview portal** (purview.microsoft.com), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling. The output is not an enforced control; it is the **evidence base and the roadmap** that makes a later enforcement project succeed: a documented picture of current DLP posture, a data map of where sensitive information actually resides

and travels, and a ringed, simulation-first rollout plan with priorities set by real exposure — not guesswork.

> ***Scope boundary.*** *This solution produces the* ***technical assessment, the discovery evidence, and the proposed roadmap****. *Which* data is regulated, *which* classifiers legally apply, *what* the enforced action must eventually be, and *which* categories are in scope are* ***business, compliance, privacy, and legal determinations*** *— deferred to those functions. We map the terrain and recommend the route; the governance owners decide the destination.*

Why this matters

• **DLP without a data map produces noise, not protection.** A policy scoped to "credit card numbers

everywhere, block on match" with no idea where card data lives will fire on internal reference numbers, bury the help desk, and be disabled within a week. Discovery first is the difference.

• **Priorities should follow exposure, not opinion.** The category worth enforcing first is the one with

the most sensitive data in the most exposed locations (externally shared sites, high-volume mail flows), not the one someone remembered in a meeting. This solution ranks by measured prevalence.

• **A baseline you can defend.** "We assessed our DLP posture, discovered where sensitive data resides, and

produced a prioritized rollout plan" is a defensible compliance position. An empty DLP blade is not.

• **The classification layer you build here pays off everywhere.** The same sensitive information types and

labels that drive the assessment later drive DLP enforcement, auto-labeling, and insider risk — get the discovery right once and reuse it across the Purview estate.

How it works

1. **Posture assessment (Assess).** Enumerate what already exists: current DLP policies and their **mode**

(enforce / simulation / disabled), sensitive information type (SIT) coverage (built-in vs custom), sensitivity and retention labels in play, whether **audit logging** and **Content Explorer** are available, and the licensing/role readiness that gates the discovery tools. Delivered read-only.

1. **Sensitive-data discovery (Assess).** Find **where sensitive data actually is**. Purview's

Content Explorer (Data classification → Content explorer) shows, per SIT and per label, the actual files and locations across Exchange, SharePoint, OneDrive, and Teams. **Activity Explorer** shows how labelled/sensitive content is being **used and shared**. Where content has never been evaluated, **on-demand / auto-classification** can be pointed at it. The delivered data-scan tool exports Content Explorer results into a data map.

1. **A monitor-only simulation baseline (Configure — no user impact).** To measure *movement* (not just

data at rest), the solution stands up **one broad DLP policy in SIMULATION mode** across all locations — Microsoft's built-in test mode that records what *would* match against real traffic with **zero** user impact. This populates real match data by SIT, location, and volume for the prioritization, and is never enforced.

1. **Prioritize (Design).** Combine the data map (where sensitive data rests) with the simulation matches (how it moves) into a **ranked exposure view** — which data categories, in which locations, at what volume and external-sharing exposure. That ranking is the backbone of the roadmap.

1. **Roadmap (Design).** Produce the **prioritized DLP rollout strategy**: which category to enforce first, in what location, with which detector and action, on which pilot ring, in what order — every step **simulation-first**, with pass/fail gates and rollback, ready to hand to an enforcement project.

What "sensitive-data discovery" draws on (all Microsoft-native)

- **Content Explorer** — the current inventory of where each SIT and label is detected across workloads (requires the **Content Explorer List/Content Viewer** roles; **verify your licensing/tenant**).
- **Activity Explorer** — how sensitive/labelled content is used and shared over time.
- **On-demand / automatic classification** — evaluates content that classification hasn't yet reached (availability is plan-dependent — **verify your licensing/tenant**).
- **The monitor-only simulation DLP policy** — measures real movement of sensitive content with no enforcement.
- **Data Security Posture Management (DSPM)**, where licensed, aggregates much of this into a posture view — used as a cross-check, **verify availability in your tenant**.

The assess→roadmap journey (the core discipline)

> *Baseline current DLP **posture** → **discover** where sensitive data rests (Content Explorer) and how it moves (monitor-only **simulation** policy + Activity Explorer) → **rank** data categories by exposure → produce a **prioritized, simulation-first rollout roadmap** with per-step detector, action, ring, gate, and rollback → hand off to an enforcement project. **Nothing in this solution enforces anything.***

What you can control

- Which **workloads** the discovery covers (Exchange, SharePoint, OneDrive, Teams) and which **SITs/labels** the data scan reports on.
- The **dwell time** the monitor-only simulation baseline runs to capture representative movement.
- The **ranking inputs** and weighting for prioritization (prevalence, external-sharing exposure, volume).
- The proposed **rollout order, rings, detectors, and actions** in the roadmap — all recommendations for compliance/legal to ratify.

Limitations (be honest with buyers)

- **Discovery depth is licensing-dependent.** Content Explorer, Activity Explorer, advanced/trainable

classifiers, on-demand classification, and DSPM are gated behind **E5 / the E5 Compliance add-on** and some are in **preview** — this solution flags "verify your licensing/tenant" rather than asserting availability. With lower plans the assessment is narrower (built-in SITs, basic reporting).

- **Discovery sees what classification can evaluate.** Strongly encrypted, unrecognized formats, or content

never scanned may not appear; on-demand classification narrows but does not eliminate this gap.

- **This is an assessment, not an enforced control.** The monitor-only simulation policy protects nothing —

it measures. Protection comes from the *enforcement* project this roadmap feeds.

- **The roadmap is a recommendation.** Scope, legal applicability, and enforced actions are compliance/

privacy/legal determinations — the strategy proposes; those functions decide.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Posture baseline export	`DLP Posture – Baseline – Assessment`
Sensitive-data map (Content Explorer export)	`Data Discovery – Content Explorer – Assessment`
Monitor-only simulation policy	`DLP Baseline – All Locations – Simulation`
Simulation rule (monitor-all)	`Monitor All SITs – All Locations – Simulation`
Ranked exposure view	`Sensitive Data Map – Prioritized – Assessment`
Rollout roadmap deliverable	`DLP Roadmap – Prioritized – Strategy`
First rollout pilot ring (proposed)	`DLP Rollout Ring – Stage1`

The standard deployment model

> ***Assess*** *current posture and discover where sensitive data rests and moves →* ***Design*** *the prioritized rollout roadmap →* ***Configure*** *the monitor-only* ***simulation*** *baseline (no user impact) →* ***Pilot*** *the discovery over an agreed dwell time →* ***Validate*** *the assessment against pass/fail gates (posture baselined, data mapped, movement measured, roadmap ranked) →* ***Expand*** *by handing the roadmap to the enforcement project. Every step is non-enforcing and reversible; the only Purview object created is a simulation policy that can be deleted with zero user impact.*

2. Requirements — Enterprise DLP Assessment & Strategy (Microsoft Purview)

These are the **solution-specific** prerequisites for running a DLP posture assessment, sensitive-data discovery, and rollout-strategy exercise in Microsoft Purview. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the discovery surfaces you will use

- **Description:** The **posture baseline** (existing policies, built-in SITs) is broadly available, but the

discovery depth that makes this assessment valuable — **Content Explorer**, **Activity Explorer**, **on-demand / automatic classification**, **advanced & trainable classifiers**, and **Data Security Posture Management (DSPM)** — is **plan-gated**, typically **Microsoft 365 E5** or the **E5 Compliance** add-on, and some capabilities are in **preview**. This extends GR-#1 with the assessment-specific detail.

- **Why required:** A discovery exercise that cannot open Content Explorer or run a simulation policy can

only inventory what exists on paper; the data map and movement measurement need these surfaces.

- **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the

Purview portal → **Data classification** confirm **Content explorer** and **Activity explorer** are visible and populated. **Flag "verify your licensing/tenant"** — availability evolves.

- **How to implement if missing:** Acquire/assign E5 / E5 Compliance for the assessment window, or scope

the assessment to the surfaces your plan covers (built-in SITs, DLP simulation, basic reporting) and note the coverage gap in the roadmap.

2.2 Assessment-specific least-privilege roles (read-heavy)

- **Description:** This is a **read-and-assess** engagement, so it needs read/reporting roles more than

authoring ones: **Content Explorer List Viewer** and **Content Explorer Content Viewer** (to see where SITs/labels are detected and the underlying items), **View-Only DLP Compliance Management** (to read DLP policies), the **Compliance Administrator / Compliance Data Administrator** role only where the monitor-only simulation policy must be *created*, and **View-Only Audit Logs** for reporting. Global Administrator only where genuinely required. Extends GR-#2.

- **Why required:** Content Explorer's two viewer roles are **separately gated** and are the single most

common blocker — without them the data map is empty. Separating read (assessment) from write (the one simulation policy) keeps the blast radius near zero.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** — confirm your account's

membership in the Content Explorer viewer roles and the DLP view/author roles you need.

• **How to implement if missing:** Assign the least-privilege role groups under change control; grant the Content Explorer **Content Viewer** role deliberately (it exposes item content) and log who holds it.

2.3 Audit logging enabled and retaining data

• **Description:** The **unified audit log** must be **enabled** and retaining events, because the movement measurement (simulation DLP matches, sharing activity) and the reporting script read from it and from Activity Explorer, both of which depend on audit ingestion.

• **Why required:** If audit logging is off or was only just turned on, there is no history of how sensitive content moves — the "how it moves" half of discovery is blank and priorities can't be ranked by movement.

• **How to verify: Purview portal** → **Audit** — confirm auditing is **On**; `Get-AdminAuditLogConfig` shows `UnifiedAuditLogIngestionEnabled : True`. The delivered Validation script checks this.

• **How to implement if missing:** Enable unified audit logging and allow ingestion/dwell time before relying on movement data; note that history only accrues from the enablement date.

2.4 A defined classification intent and a data-category shortlist

• **Description:** A documented view of **what sensitive data the organization believes it holds** (payment

card data, national IDs, health identifiers, customer PII, source code, contracts, etc.) mapped to the **SITs/labels** that would detect it — used to focus Content Explorer and the simulation policy on the categories that matter. Extends GR-#4.

• **Why required:** Discovery is far more useful when aimed. A shortlist of candidate categories turns an open-ended scan into a targeted data map and makes the resulting prioritization legible to stakeholders.

• **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists built-in and custom SITs; confirm the ones matching your candidate categories exist. Confirm the shortlist with data owners.

• **How to implement if missing:** Build the candidate-category shortlist with the data owners before the scan; where no built-in SIT fits a category, note it as a **detector gap** for the roadmap (custom SIT / EDM / trainable classifier to be built during enforcement, not here).

2.5 Approval to create ONE monitor-only simulation DLP policy

• **Description:** Change-control approval to create a **single tenant-wide DLP policy in SIMULATION mode**

(`DLP Baseline – All Locations – Simulation`) whose only purpose is to **measure** what would match — it takes **no enforcement action** and shows **no policy tips** to users. Extends GR-#6.

• **Why required:** Measuring movement needs a policy evaluating real traffic; simulation mode does exactly

that with zero user impact. Even a zero-impact object should pass change control so its purpose and its simulation-only status are on record and it isn't mistaken for an enforcing policy.

• **How to verify:** Confirm the approval and that the intended mode is **simulation** (never enforce). The

Validation script flags any policy found in **enforce** mode that the assessment did not intend.

• **How to implement if missing:** Obtain approval for the one simulation policy; if even that is not

permitted, run discovery on **data-at-rest only** (Content Explorer) and note that movement data is unavailable in the roadmap.

2.6 An assessment scope, dwell time, and stakeholder sign-off path

• **Description:** The **workloads and (optionally) sites/users** the assessment covers, a **dwell time**

for the simulation baseline (long enough to capture representative movement — often 2–4 weeks), and the **stakeholder path** (compliance/privacy/legal/records) that will **review and ratify** the resulting roadmap. Extends GR-#5 and GR-#6.

• **Why required:** The assessment's output is a *recommendation*; it only becomes an enforcement mandate

once the governance owners ratify scope, legal applicability, and enforced actions. The dwell time governs how representative the movement data is.

• **How to verify:** Confirm the covered workloads, the agreed dwell time, and the named reviewers/approvers

for the roadmap.

• **How to implement if missing:** Agree scope and dwell time and identify the roadmap reviewers before

starting, so the deliverable has a home and an owner.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	Discovery-surface licensing (Content/Activity Explorer, DSPM; verify)	Data map + movement measurable
2.2	Read-heavy least-privilege roles (incl. Content Explorer viewers)	Discovery tools can read
2.3	Unified audit logging enabled + retaining	Movement history available
2.4	Classification intent + candidate-category shortlist	Discovery is aimed, results legible

#	Requirement	Gate
2.5	Approval for ONE monitor-only simulation policy	Movement measurable, zero user impact
2.6	Assessment scope + dwell time + roadmap sign-off path	Representative data + a ratified output

> ***Deferred to compliance/privacy/legal:*** *which data categories are ultimately in scope, which classifiers legally apply, the enforced action per category, and any regulatory applicability. This solution delivers the assessment, the discovery evidence, and the proposed roadmap — not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Enterprise DLP Assessment & Strategy (Microsoft Purview)

This is the exact, ordered procedure to run a DLP posture assessment, discover where sensitive data rests and moves, and produce a **prioritized, simulation-first rollout roadmap** — **without enforcing anything**. The only Purview object created is a single **monitor-only DLP policy in SIMULATION mode**. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. Four are **read-only**; the one that creates the simulation baseline is `-WhatIf` **by default** and requires an explicit `-Commit` — and it **never** creates anything but a simulation policy. No credentials are stored in code.*
>
> ***Determinations deferred.*** **Which* data categories are ultimately in scope, *which* classifiers legally apply, and the *enforced action* per category are **compliance/privacy/legal** decisions. This guide produces the assessment and the recommended roadmap; those functions ratify it.*

Phase 0 — Connect and baseline current posture (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','InformationProtectionPolicy.Read' -NoWelcome
```

1. **Run the posture assessment** (delivered script #1, read-only) → `DLP Posture – Baseline – Assessment`:

```
.\DLPASSESS-Discovery.ps1 -CsvPath .\DLPASSESS-Posture.csv
```

It reports existing DLP policies and their **mode** (enforce / simulation / disabled), built-in vs custom **SIT** coverage, **sensitivity/retention labels** present, and audit-logging / Content-Explorer readiness signals.

1. **Confirm discovery readiness** (delivered script #3, read-only): audit logging **On** (Req 2.3), the

Content Explorer viewer roles held (Req 2.2), and the discovery surfaces visible (Req 2.1):

```
.\DLPASSESS-Validation.ps1
```

Pass/fail gate: you have a written posture baseline (policies + modes + SIT/label coverage) and the Validation script confirms audit logging is on and the Content Explorer roles/surfaces are available (or the gaps are documented). **No enforcing DLP policy is present that the assessment did not expect. Rollback:** none (read-only).

Phase 1 — Discover where sensitive data RESTS (Assess — data at rest)

Aim the scan at your candidate categories (Req 2.4). Do **not** invent SITs — report on built-in ones and any existing custom ones.

1. **Review Content Explorer in the portal. Purview portal** → **Data classification** → **Content explorer.**

Browse by **Sensitive info type** and by **Sensitivity/Retention label** to see the actual files/locations across **Exchange, SharePoint, OneDrive, and Teams**. This requires the **Content Explorer List Viewer / Content Viewer** roles (Req 2.2) — **verify your licensing/tenant.**

1. **Export the data map** (delivered script #2, read-only) → `Data Discovery – Content Explorer – Assessment`:

```
.\DLPASSESS-DataScan.ps1 -Tags 'Credit Card Number','U.S. Social Security Number (SSN)' -CsvPath .\DLPA
```

It uses `Export-ContentExplorerData` to record, per SIT/label, the **count and location** of detected items — the data-at-rest half of the map. Pass the SIT/label names from your shortlist.

1. **Note detector gaps.** For a candidate category with **no built-in SIT** (e.g. an internal Employee ID),

record it as a **detector-to-build** item for the roadmap (custom SIT / EDM / trainable classifier — built during the *enforcement* project, not here).

1. **Optional — reach unscanned content.** Where classification hasn't evaluated a location, note

on-demand / automatic classification as a follow-up (availability is plan-dependent — **verify your licensing/tenant**); do not assume every store has been scanned.

Pass/fail gate: every candidate category maps to a **detected-item count and location profile** (or is explicitly recorded as a detector gap). You can say where each sensitive-data category rests. **Rollback:** none (read-only export).

Phase 2 — Stand up the monitor-only SIMULATION baseline (Configure — no user impact)

To measure **movement** (not just data at rest), create **one** broad DLP policy in **simulation mode**. It evaluates real traffic and records what *would* match — with **no** enforcement and **no** policy tips.

1. **Create the simulation baseline** (delivered script #4 — `-WhatIf` by default; `-Commit` to create) → `DLP Baseline – All Locations – Simulation` with rule `Monitor All SITs – All Locations – Simulation`:

```
.\DLPASSESS-Baseline.ps1 -WhatIf                    # preview the intended policy — no change
.\DLPASSESS-Baseline.ps1 -Commit                    # create it in SIMULATION mode only
```

Portal equivalent: **Data loss prevention** → **Policies** → **Create policy** → custom → **Locations: Exchange, SharePoint, OneDrive, Teams** (add **Devices** only if endpoints are onboarded and licensed — Req 2.1) → rule: condition *Content contains* your shortlist SITs at a **low, inclusive** confidence/instance count (the goal is to *see* movement, not to tune yet) → **no action** / audit-only → **Policy mode: Run the policy in simulation mode** (without policy tips). Finish.

1. **Confirm it is in simulation, not enforce.** Re-run script #1 or #3:

```
.\DLPASSESS-Discovery.ps1
```

The baseline must report a **Test*** mode (`TestWithoutNotifications`). If anything shows **Enable** (enforcing) that you didn't intend, stop and correct it.

Pass/fail gate: exactly one broad DLP policy exists, confirmed in **simulation** (Mode = `TestWithoutNotifications`), scoped to the intended locations and the shortlist SITs. Nothing is enforced. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is instant and clean (`.\DLPASSESS-Baseline.ps1 -Remove -Commit`).

Phase 3 — Measure how sensitive data MOVES (Pilot the discovery)

Let the simulation baseline run for the agreed **dwell time** (Req 2.6) to capture representative traffic.

1. **Review what would have matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and **Data classification** → **Activity explorer** (filter to DLP + sharing activities) show every simulated match — the file/message, the SIT, the location, and whether it was **shared externally**.

1. **Export the movement data** (delivered script #5, read-only):

```
.\DLPASSESS-Report.ps1 -Days 21 -CsvPath .\DLPASSESS-Movement.csv
```

It aggregates simulation DLP matches (and sharing events) by **SIT, workload, volume, and external exposure** — the data-in-motion half of the map.

1. **Confirm coverage.** If a candidate category shows **zero** movement, decide whether that is genuine (data at rest only) or a **coverage gap** (dwell too short, location not covered, audit latency) — note which in the roadmap.

Pass/fail gate: you have measured movement (matches by SIT/workload/volume/external-exposure) over a representative dwell time, reconciled against the Phase-1 data-at-rest map. **Rollback:** none (read-only); the simulation policy keeps running or is deleted (Phase 2 rollback).

Phase 4 — Rank exposure and build the roadmap (Design)

1. **Rank data categories by exposure** → `Sensitive Data Map – Prioritized – Assessment`. Combine the

data-at-rest map (Phase 1) with the movement data (Phase 3) into a ranked view, weighting by: **prevalence** (how much of each category exists), **external-sharing exposure** (how much leaves or is shared out), **movement volume**, and **detector confidence** (built-in vs a gap to build). The reporting script emits this ranking; adjust the weighting with stakeholders.

1. **Draft the rollout roadmap** → `DLP Roadmap – Prioritized – Strategy`. For each ranked category, specify

the recommended: **detector** (built-in SIT / custom / EDM / trainable — flag gaps to build), **location(s)** to cover first, **action progression** (audit → policy tip → allow-with-justification → block), the **pilot ring** (`DLP Rollout Ring – Stage1`), and the **order**. **Every step is simulation-first** with a pass/fail gate and a rollback — matching the house model.

1. **Mark determinations for ratification.** Explicitly flag every point that is a **compliance/privacy/

legal decision **— which categories are truly in scope, which classifiers legally apply, and the enforced action per category — as** [to be ratified]** in the roadmap, not decided here.

Pass/fail gate: a ranked exposure view and a prioritized, simulation-first roadmap exist, every step is gated and reversible, and every governance determination is flagged for ratification (not assumed). **Rollback:** none (documentation); the roadmap is a recommendation until ratified.

Phase 5 — Review, ratify, and hand off (Expand)

1. **Walk stakeholders through the roadmap** (Req 2.6): compliance/privacy/legal/records review the ranked

exposure, the proposed order, detectors, and actions, and **ratify or revise** scope and enforced-action determinations.

1. **Record the ratified decisions** back into `DLP Roadmap – Prioritized – Strategy` — scope confirmed,

actions per category agreed, detector-build backlog captured.

1. **Decide the simulation baseline's fate.** Either **keep** `DLP Baseline – All Locations – Simulation`

running as an ongoing monitor into the enforcement project, or **delete** it (Phase 2 rollback) — it is non-enforcing either way. Document the choice.

1. **Hand off to the enforcement project.** The ratified roadmap, the data map, the movement report, and the

detector-build backlog are the complete input to a DLP *enforcement* engagement (e.g. the DLP: Endpoint/Cloud/Email solution) — which starts, as always, in simulation.

Pass/fail gate: the roadmap is ratified by the governance owners, decisions are recorded, the simulation baseline's disposition is documented, and the enforcement project has everything it needs to start. **Rollback:** delete the simulation policy at any time (instant, no user impact); all other outputs are documents.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline posture, confirm readiness	Posture CSV	Baseline + readiness confirmed	n/a (read-only)
1 Rest	Discover where sensitive data rests (Content Explorer)	Data map CSV	Every category → location profile	n/a (read-only)
2 Configure	Create ONE monitor-only **simulation** policy	Simulation baseline	In simulation, correct scope, nothing enforced	Delete sim policy
3 Motion	Measure movement over dwell time	Movement CSV	Movement measured + reconciled	n/a (read-only)
4 Design	Rank exposure, build roadmap	Ranked map + roadmap	Ranked, gated, reversible, flagged	n/a (docs)
5 Ratify	Review, ratify, hand off	Ratified roadmap	Ratified + handed off	Delete sim policy

5. Testing & Validation — Enterprise DLP Assessment & Strategy (Microsoft Purview)

Validate the assessment against explicit **pass/fail gates**. Because this solution **enforces nothing**, the gates are about *completeness and correctness of the evidence and the roadmap*, not about blocking leaks. The four headline gates are: **(A) posture is baselined**, **(B) sensitive data is discovered (rest + motion)**, **(C) exposure is ranked and the roadmap is sound**, and **(D) nothing is enforced and everything is reversible**. Where any test touches sample content, use **non-real, clearly-fake data** (e.g. the Microsoft-documented test credit-card number `4111 1111 1111 1111`) — never real customer/employee data.

> *All tests assume the posture baseline (Phase 0), the Content Explorer data map (Phase 1), the monitor-only simulation policy (Phase 2), and the movement measurement (Phase 3) from the Implementation Guide.*

Test A — Posture baseline (Assess)

#	Test	Steps	Pass condition
A1	Policy inventory captured	Run `DLPASSESS-Discovery.ps1 -CsvPath ...`	Every existing DLP policy is listed with its **mode** (enforce / simulation / disabled) and locations; the CSV is produced.

#	Test	Steps	Pass condition
A2	SIT/label coverage mapped	Review the Discovery output.	Built-in vs custom SIT counts and the sensitivity/retention labels in play are recorded.
A3	Unexpected enforcement flagged	Review the "enforcing policies" callout.	Any policy in **Enable** (enforce) mode is flagged for review; if none is expected, the list is empty.

Gate A (pass): a written posture baseline exists — policies + modes + SIT/label coverage — and any pre-existing enforcement is identified.

Test B — Sensitive-data discovery (rest + motion)

#	Test	Steps	Pass condition
B1	Readiness confirmed	Run `DLPASSESS-Validation.ps1`.	Audit logging **On**, Content Explorer viewer roles held (or gap documented), discovery surfaces available.
B2	Data-at-rest map produced	Run `DLPASSESS-DataScan.ps1 -Tags <shortlist> -CsvPath ...`.	Per-SIT/label **item counts and locations** are exported for the candidate categories (or a category is explicitly a detector gap).
B3	Simulation baseline live	Run `DLPASSESS-Discovery.ps1` after creating the baseline.	Exactly one broad policy reports a **Test*** mode (`TestWithoutNotifications`) over the intended locations/SITs.
B4	Movement measured	After dwell time, run `DLPASSESS-Report.ps1 -Days <n> -CsvPath ...`.	Simulated matches are aggregated by **SIT, workload, volume, and external exposure**; the CSV is produced.
B5	Rest↔motion reconciled	Compare B2 and B4.	Categories with data at rest but zero movement (or vice-versa) are explained as genuine or as a coverage gap.

Gate B (pass): you can state, with evidence, **where each candidate category rests and how it moves**, with any coverage gaps documented.

Test C — Ranking & roadmap quality (Design)

#	Test	Steps	Pass condition
C1	Exposure ranked	Review `Sensitive Data Map – Prioritized – Assessment`.	Categories are ranked by prevalence, external-sharing exposure, and movement volume — with the weighting recorded.
C2	Roadmap is simulation-first	Review each roadmap step.	Every proposed rollout step starts in **simulation**, has a **pass/fail gate** and a **rollback**, and names a detector, location, action, ring, and order.
C3	Detector gaps captured	Check categories with no built-in SIT.	Each is listed as a **detector-to-build** backlog item (custom SIT / EDM / trainable), not silently dropped.
C4	Determinations flagged	Scan the roadmap for scope/action decisions.	Every compliance/privacy/legal decision is marked **[to be ratified]** — none is asserted by the assessment.

Gate C (pass): a defensible ranking and a simulation-first, gated, reversible roadmap exist, with detector gaps and governance determinations explicitly flagged.

Test D — Non-enforcement & reversibility (safety)

#	Test	Steps	Pass condition
D1	Nothing enforced	Run `DLPASSESS-Discovery.ps1`.	The only policy this solution created is in **simulation**; no user is blocked or tipped by it.
D2	Zero user impact	Confirm with a pilot user that normal email/sharing is unaffected.	Users experience **no** policy tips or blocks from the assessment baseline.

#	Test	Steps	Pass condition
D3	Instant rollback	Run `DLPASSESS-Baseline.ps1 -Remove -Commit` (or delete in portal).	The simulation policy is removed cleanly with no data change and no user impact.
D4	Scripts safe-by-default	Run `DLPASSESS-Baseline.ps1` **without** `-Commit`.	It makes no change (`-WhatIf` output only); Discovery / DataScan / Validation / Report are read-only.

Gate D (pass): the assessment enforced nothing, imposed zero user impact, and every created object is instantly and cleanly removable.

Evidence to capture (for the deliverable record)

- The posture baseline CSV (Phase 0) and the SIT/label coverage summary (Gate A).
- The Content Explorer data-at-rest map and the movement report, plus the rest↔motion reconciliation

(Gate B).

- The ranked exposure view and the prioritized, simulation-first roadmap with detector gaps and

[to be ratified] flags (Gate C).

- Confirmation that the only created policy was in **simulation**, caused no user impact, and was removable

(Gate D).

- The stakeholder ratification record (who reviewed, what was ratified/revised).

> ***Determination boundary.*** *These tests prove the* ***assessment and the roadmap are complete and non-enforcing****. Whether a given category is *in scope*, which classifier *legally applies*, and the *enforced action per category* are compliance/privacy/legal sign-offs, captured alongside the evidence above.*

6. Troubleshooting — Enterprise DLP Assessment & Strategy (Microsoft Purview)

Symptom-first fixes for the failures you actually hit running a DLP assessment. Most problems are one of: Content Explorer empty or access-denied, the simulation baseline not producing matches, no movement data in reports, or the exposure ranking coming out unusable.

Discovery — data at rest (Content Explorer)

Content Explorer / `DLPASSESS-DataScan.ps1` **returns nothing or "access denied."**

• **Roles:** Content Explorer needs the **Content Explorer List Viewer** and **Content Explorer Content Viewer **roles — these are** separately assigned **from other compliance roles and are the #1 blocker. Confirm both in** Purview portal → Settings → Roles & scopes → Permissions** (Req 2.2). Run `DLPASSESS-Validation.ps1` — it reports whether `Export-ContentExplorerData` is reachable.

• **Licensing:** Content Explorer is **E5 / E5 Compliance** and evolves — **verify your licensing/tenant.** If it isn't available, the assessment is limited to data-in-motion (simulation) + built-in-SIT posture.

• **Tag name mismatch:** `-Tags` must match the **exact SIT/label name** as Purview lists it (e.g. `U.S. Social Security Number (SSN)`, not `SSN`). A wrong name returns nothing.

A candidate category returns zero items.

• It may be **genuine** (you don't hold that data) — record it as such.

• Or the content **hasn't been classified yet** — classification is a background process; newly added content or never-scanned stores may not appear. Note it and consider **on-demand/auto-classification** (plan-dependent — verify your tenant).

• Or there is **no detector** for the category (e.g. an internal ID with no matching SIT) — record it as a **detector-to-build** backlog item for the roadmap, not a hole.

Configuration — the monitor-only simulation baseline

`DLPASSESS-Baseline.ps1` **makes no change.**

• That is **correct by default** — it runs in `-WhatIf` unless you pass `-Commit`. Re-run with `-Commit` to actually create the policy.

Policy creation fails with a permissions error.

• Creating a DLP policy needs **Compliance Administrator** or **Compliance Data Administrator** (Req 2.2).

View-only roles can read but not create — assign the author role under change control, then re-run.

The baseline was created but shows no matches after days.

• Confirm it is actually **in simulation and evaluating**: `DLPASSESS-Discovery.ps1` should show it as `TestWithoutNotifications`. A **disabled** policy does nothing.

• **Propagation latency:** new DLP policies can take **up to ~1 hour (longer for some locations)** to start evaluating. Wait before concluding it's broken.

• Confirm the rule's **SITs and minCount** are inclusive enough — for an assessment you want a **low** instance count so you *see* movement (tuning comes later, in the enforcement project).

• Confirm **audit logging is on** (`DLPASSESS-Validation.ps1`) — matches surface through the audit log.

I need the baseline gone.

- `.\DLPASSESS-Baseline.ps1 -Remove -Commit` (or delete in the portal). Because it is simulation-only,

removal is instant with **zero** user impact and no data change.

Discovery — data in motion (reporting)

`DLPASSESS-Report.ps1` **returns no matches.**

- **No baseline / not simulating:** confirm `DLP Baseline – All Locations – Simulation` exists and is in a

`Test*` mode (`DLPASSESS-Discovery.ps1`).

- **Audit log latency / dwell:** DLP events take time to appear; widen `-Days` and re-run, and allow the

agreed **dwell time** (Req 2.6) before expecting representative data.

- **Audit logging off / missing role:** confirm audit ingestion is on and your account holds a

View-Only DLP / audit role.

The external-exposure count looks wrong.

- The report infers external exposure from sharing type / recipient domain and treats non-`contoso.com`

recipients as external — **edit the internal-domain check** in the script to your real domain(s) so the external signal is accurate for your tenant.

Ranking & roadmap

The exposure ranking is dominated by one noisy SIT.

- A broad built-in SIT (e.g. a permissive number pattern) can over-count. For the assessment that's fine —

note it as a **tuning item** for the enforcement project (raise confidence/instance count there). Don't tune the assessment baseline into an enforcement policy; keep it monitor-only.

Data at rest and data in motion don't reconcile.

- Expected and useful: a category with lots of data at rest but little movement is a *storage* risk; one

with little at rest but high external movement is an *egress* risk. Record **both** — they inform different rollout priorities. A category with neither may be a coverage gap (dwell too short, location not covered, not yet classified).

Connectivity / tooling

`Connect-IPPSSession` **or a cmdlet fails.**

- Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth /

MFA-capable** admin. A missing role surfaces as "cmdlet not recognized" or access denied — confirm the role for the specific cmdlet (DLP author vs Content Explorer viewer vs audit).

A script made an unexpected change.

• Only `DLPASSESS-Baseline.ps1` writes, only with `-Commit`, and only ever creates a **simulation** policy —

the safe recovery is always to **remove** it (`-Remove -Commit`), which is clean and user-impact-free. The other four scripts are read-only.

Fast triage table

Symptom	First check
Content Explorer empty / denied	Content Explorer **viewer roles** (both), licensing, exact tag name
Category returns zero at rest	Genuine zero, not-yet-classified, or a detector gap — record which
Baseline makes no change	Missing `-Commit` (WhatIf is the default)
Policy create fails	Need Compliance (Data) Administrator role
Baseline shows no matches	Mode = Test*? propagation latency, minCount, audit on
Report returns nothing	Baseline live+simulating, audit on, dwell time, `-Days`
External count wrong	Edit the internal-domain check to your real domain
Ranking skewed by one SIT	Note as enforcement-project tuning; keep baseline monitor-only
Cmdlet/connect fails	Module updated, modern auth, correct role for that cmdlet

7. Best Practices — Enterprise DLP Assessment & Strategy (Microsoft Purview)

Field-tested practices for running a DLP assessment that produces a roadmap people actually trust and act on — rather than a shelf-ware report. These complement the Implementation and Testing guides.

Discover before you design — always

• **Never propose a DLP policy before you know where the data is.** The whole point of this engagement is

to replace "we think we should block credit cards" with "here is where card data rests and how it moves." Let Content Explorer and the simulation baseline speak before you rank anything.

• **Aim the scan.** An open-ended "scan everything" produces an unreadable map. Start from a **candidate-

category shortlist** (Req 2.4) so the data map and the ranking are legible to compliance and legal.

• **Measure motion, not just rest.** Data at rest tells you *what* you hold; the monitor-only simulation

policy and Activity Explorer tell you *how it leaves* — and external-sharing exposure is usually the single strongest prioritization signal.

Keep the assessment non-enforcing and reversible

- **Exactly one Purview object** should come out of this engagement: the `DLP Baseline – All Locations –

Simulation` policy. It enforces nothing and shows no tips. Treat **simulation mode as a measurement instrument**, not a control.

- **Confirm the mode every time.** After any change, re-run Discovery and verify the baseline reads

`TestWithoutNotifications`. An assessment policy that drifts to enforce is a self-inflicted incident.

- **Make removal trivial.** The baseline should be deletable in one step with zero user impact — and you

should test that (`-Remove -Commit`) so the rollback is proven, not assumed.

Rank by exposure, not opinion

- **Weight external exposure heavily.** A category shared "anyone with the link" out of SharePoint is a

higher priority than a higher-volume category that never leaves the tenant. Prevalence × external exposure × movement volume beats gut feel.

- **Record the weighting.** Whatever formula you use to rank, write it down and agree it with stakeholders —

a ranking whose logic is opaque gets argued with instead of acted on.

- **Surface the gaps as first-class output.** A candidate category with **no built-in detector** is not a

hole to hide — it is a **detector-to-build** backlog item (custom SIT / EDM / trainable) for the enforcement project. Naming it is part of the value.

Right-size the roadmap for an enforcement project

- **Every roadmap step is simulation-first.** Carry the house model forward: each proposed rollout stage

starts in simulation, has a pass/fail gate and a rollback, and names its detector, location, action, ring, and order — so the enforcement team can pick it up and run it.

- **Sequence by ring, not big-bang.** Recommend a `DLP Rollout Ring – Stage1` pilot for the first category/

location, then expansion — never a tenant-wide enforce as step one.

- **Progress the action, don't start at block.** Recommend audit → policy tip → allow-with-justification →

block per category, so the enforcement project can adopt without a wall of false positives.

Respect the discovery's licensing and privacy boundaries

• **Verify licensing/tenant before promising depth.** Content Explorer, Activity Explorer, on-demand

classification, trainable classifiers, and DSPM are E5 / E5-Compliance and some are preview — scope the assessment to what the plan actually provides and note the gap, don't assert a capability you can't run.

• **Guard the Content Explorer Content Viewer role.** It exposes actual item content — grant it deliberately,

to as few people as possible, log who holds it, and remove it when the assessment ends.

• **Discovery is privacy-sensitive.** You are looking at where personal and sensitive data lives — keep the

data map access-controlled, don't copy sensitive samples out of Purview, and involve privacy stakeholders in how the evidence is handled.

Hand off cleanly and stay inside the boundary

• **Ratify before you enforce.** The roadmap is a recommendation until compliance/privacy/legal/records

ratify scope and enforced actions. Flag every such decision **[to be ratified]** — don't let the assessment quietly become policy.

• **The determinations are theirs.** Which categories are in scope, which classifiers legally apply, and the

enforced action per category are governance decisions — you provide the exposure evidence and the technical route, they own the destination.

• **The assessment feeds enforcement; it isn't enforcement.** The output is a data map, a movement report,

a ranked exposure view, a detector-build backlog, and a ratified roadmap — the complete, de-risked input to a DLP *enforcement* engagement that will, as always, start in simulation.

8. Deliverables Summary — Enterprise DLP Assessment & Strategy (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The assess→roadmap model — posture baseline, sensitive-data discovery (Content Explorer for data at rest, a monitor-only simulation policy for data in motion), exposure ranking, and a prioritized rollout roadmap; naming convention.

Document	What it gives you
Requirements Guide	Solution-specific prerequisites (discovery-surface licensing, read-heavy roles incl. Content Explorer viewers, audit logging, classification intent + candidate-category shortlist, approval for one simulation policy, scope/dwell/sign-off path) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: baseline posture → discover data at rest → stand up a monitor-only **simulation** policy → measure movement → rank exposure and build the roadmap → ratify and hand off; each phase named, gated, and reversible — **nothing is enforced**.
Testing & Validation	Pass/fail gates for the four outcomes — posture baselined (A), sensitive data discovered rest+motion (B), exposure ranked / roadmap sound (C), nothing enforced & reversible (D) — with fake test data only.
Troubleshooting Guide	The common failure modes (Content Explorer empty/denied, simulation policy not matching, no movement data, roadmap can't be ranked) and how to resolve them.
Best Practices	Discover-before-design discipline, non-enforcing/reversible assessment, ranking by exposure, roadmap shaped for an enforcement project, and licensing/privacy boundaries.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only** except the simulation-baseline helper, which is `-WhatIf` **by default** and requires an explicit `-Commit` (and only ever creates a **simulation** policy). No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**DLPASSESS-Discovery.ps1**	DLP posture baseline: existing policies and their mode, built-in vs custom SIT coverage, sensitivity/retention labels, audit/Content-Explorer readiness signals.	Read-only

#	Script	Role	Default safety
2	**DLPASSESS-DataScan.ps1**	Sensitive-data discovery (data at rest): exports Content Explorer results per SIT/label — item counts and locations across Exchange/SPO/OneDrive/Teams.	Read-only
3	**DLPASSESS-Validation.ps1**	Readiness & non-enforcement gate: audit logging on, Content Explorer roles held, discovery surfaces available, and no unintended enforcing policy.	Read-only
4	**DLPASSESS-Baseline.ps1**	Monitor-only simulation baseline helper: creates/updates (or removes) the one `DLP Baseline – All Locations – Simulation` policy that measures movement. **Never** creates an enforcing policy.	`-WhatIf` (writes need `-Commit`)
5	**DLPASSESS-Report.ps1**	Exposure/movement report: aggregates simulation DLP matches by SIT, workload, volume, and external exposure — the ranking input for the roadmap.	Read-only

Definition of done

• Current DLP **posture baselined** — every policy, its mode, and SIT/label coverage recorded (Gate A).

• **Sensitive data discovered** — a data-at-rest map (Content Explorer) and a data-in-motion report (simulation baseline + Activity Explorer), reconciled, with coverage gaps documented (Gate B).

• **Exposure ranked** and a **prioritized, simulation-first rollout roadmap** produced — every step gated and reversible, detector gaps captured, governance determinations flagged **[to be ratified]** (Gate C).

• **Nothing enforced** — the only Purview object created is a simulation policy with zero user impact, proven removable; scripts safe-by-default (Gate D).

• The roadmap **ratified** by compliance/privacy/legal/records and **handed off** to a DLP enforcement project, with the detector-build backlog attached.

> ***Boundary:*** *the solution delivers the assessment, the discovery evidence, and the recommended roadmap. The* ***data categories in scope, the classifiers that legally apply, and the enforced action per category*** *are compliance/privacy/legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPASSESS-Baseline.ps1

Purpose: Stands up (or removes) a single, broad DLP policy in SIMULATION mode whose only job is to MEASURE how sensitive data moves — it takes no enforcement action and shows no policy tips. This populates real match data (by SIT, location, volume) for the exposure ranking. It is -WhatIf BY DEFAULT: nothing is created until you pass -Commit, and it will NEVER create an enforcing policy — the mode is hard-coded to TestWithoutNotifications (simulation). HOW TO RUN Preview (no change): powershell -File .\DLPASSESS-Baseline.ps1 -WhatIf Create (simulation): powershell -File .\DLPASSESS-Baseline.ps1 -Commit Remove (clean up): powershell -File .\DLPASSESS-Baseline.ps1 -Remove -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession) and a Compliance/Compliance Data Administrator role to create the policy. .EXAMPLE .\DLPASSESS-Baseline.ps1 -WhatIf Shows the policy/rule that would be created — makes no change. .EXAMPLE .\DLPASSESS-Baseline.ps1 -SensitiveTypes 'Credit Card Number','U.S. Social Security Number (SSN)' -Commit Creates the simulation baseline covering the named SITs across Exchange/SPO/OneDrive/Teams. .NOTES Purview — Enterprise DLP Assessment & Strategy. WRITE gated behind -Commit; mode is always SIMULATION. EXPECTED RESULTS: with -Commit, one policy 'DLP Baseline - All Locations - Simulation' in Mode=TestWithoutNotifications. PASS signal: DLPASSESS-Discovery.ps1 reports it as a Test* mode. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string]$PolicyName = 'DLP Baseline - All Locations - Simulation', [string]$RuleName = 'Monitor All SITs - All Locations - Simulation', [string[]]$SensitiveTypes = @('Credit Card Number','U.S. Social Security Number (SSN)'), [int]$MinCount = 1, [switch]$Remove, [switch]$Commit, [string]$UserPrincipalName)

How to run: Preview (no change): powershell -File .\DLPASSESS-Baseline.ps1 -WhatIf Create (simulation): powershell -File .\DLPASSESS-Baseline.ps1 -Commit Remove (clean up): powershell -File .\DLPASSESS-Baseline.ps1 -Remove -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession) and a Compliance/Compliance Data Administrator role to create the policy. .EXAMPLE .\DLPASSESS-Baseline.ps1 -WhatIf Shows the policy/rule that would be created — makes no change. .EXAMPLE .\DLPASSESS-Baseline.ps1 -SensitiveTypes 'Credit Card Number','U.S. Social Security Number (SSN)' -Commit Creates the simulation baseline covering the named SITs across Exchange/SPO/OneDrive/Teams. .NOTES Purview — Enterprise DLP Assessment & Strategy. WRITE gated behind -Commit; mode is always SIMULATION. EXPECTED RESULTS: with -Commit, one policy 'DLP Baseline - All Locations - Simulation' in Mode=TestWithoutNotifications. PASS signal: DLPASSESS-Discovery.ps1 reports it as a Test* mode. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string]$PolicyName = 'DLP Baseline - All Locations - Simulation', [string]$RuleName = 'Monitor All SITs - All Locations - Simulation', [string[]]$SensitiveTypes = @('Credit Card Number','U.S. Social Security Number (SSN)'), [int]$MinCount = 1, [switch]$Remove, [switch]$Commit, [string]$UserPrincipalName)

DLPASSESS-DataScan.ps1

Purpose: Builds the data-at-rest half of the sensitive-data map: for each sensitive information type (or label) you name, it exports what Content Explorer has detected — item counts and locations across Exchange, SharePoint, OneDrive, and Teams. This is the evidence for "where does each sensitive-data category actually rest?" Read-only — uses Export-ContentExplorerData only. HOW TO RUN powershell

-ExecutionPolicy Bypass -File .\DLPASSESS-DataScan.ps1 ` -Tags 'Credit Card Number','U.S. Social Security Number (SSN)' -CsvPath .\DLPASSESS-DataMap.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) AND the Content Explorer List/Content Viewer roles. Content Explorer is licensing-dependent — verify your tenant. .EXAMPLE .\DLPASSESS-DataScan.ps1 -Tags 'Credit Card Number' -TagType SensitiveInformationType Reports where the Credit Card Number SIT is detected, per workload. .EXAMPLE .\DLPASSESS-DataScan.ps1 -Tags 'Confidential' -TagType RetentionLabel -CsvPath .\map.csv Reports where the 'Confidential' label is applied and exports the map. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only. Requires Content Explorer viewer roles (they expose item content — grant deliberately). EXPECTED RESULTS: per-tag, per-workload item counts and a CSV data map. PASS signal: each candidate category resolves to a location profile, or is recorded as a detector gap (no matching SIT). > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string[]]$Tags,

How to run: powershell -ExecutionPolicy Bypass -File .\DLPASSESS-DataScan.ps1 ` -Tags 'Credit Card Number','U.S. Social Security Number (SSN)' -CsvPath .\DLPASSESS-DataMap.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) AND the Content Explorer List/Content Viewer roles. Content Explorer is licensing-dependent — verify your tenant. .EXAMPLE .\DLPASSESS-DataScan.ps1 -Tags 'Credit Card Number' -TagType SensitiveInformationType Reports where the Credit Card Number SIT is detected, per workload. .EXAMPLE .\DLPASSESS-DataScan.ps1 -Tags 'Confidential' -TagType RetentionLabel -CsvPath .\map.csv Reports where the 'Confidential' label is applied and exports the map. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only. Requires Content Explorer viewer roles (they expose item content — grant deliberately). EXPECTED RESULTS: per-tag, per-workload item counts and a CSV data map. PASS signal: each candidate category resolves to a location profile, or is recorded as a detector gap (no matching SIT). > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string[]]$Tags,

DLPASSESS-Discovery.ps1

Purpose: Builds the DLP posture baseline for a "know what to protect before you write a policy" assessment: every existing DLP compliance policy with its MODE (enforce vs simulation vs disabled) and locations, a summary of sensitive information types (built-in vs custom), and the sensitivity/retention labels present in the tenant. Read-only — makes no changes. It flags any policy already in ENFORCE mode so the assessment does not mistake it for a monitor-only one. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Discovery.ps1 -CsvPath .\DLPASSESS-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). .EXAMPLE .\DLPASSESS-Discovery.ps1 Prints the posture baseline (policies + modes, SIT coverage, labels) to the console. .EXAMPLE .\DLPASSESS-Discovery.ps1 -CsvPath .\DLPASSESS-Posture.csv -UserPrincipalName admin@contoso.com Same, plus exports the policy inventory to CSV. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only against Security & Compliance PowerShell. EXPECTED RESULTS: a table of DLP policies (Name, Mode, Locations), SIT counts, and labels. PASS signal: policies you expect are in simulation report a Test* mode; anything in Enable you did not intend is flagged for review. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Discovery.ps1 -CsvPath .\DLPASSESS-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). .EXAMPLE .\DLPASSESS-Discovery.ps1 Prints the posture baseline (policies + modes, SIT coverage, labels) to the console. .EXAMPLE .\DLPASSESS-Discovery.ps1 -CsvPath .\DLPASSESS-Posture.csv -UserPrincipalName admin@contoso.com Same, plus exports the policy inventory to CSV. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only against

Security & Compliance PowerShell. EXPECTED RESULTS: a table of DLP policies (Name, Mode, Locations), SIT counts, and labels. PASS signal: policies you expect are in simulation report a Test* mode; anything in Enable you did not intend is flagged for review. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

DLPASSESS-Report.ps1

Purpose: Builds the data-in-motion half of the map and the exposure ranking that drives the rollout roadmap. Reads simulation DLP matches from the unified audit log over a window and aggregates them by sensitive information type, workload, volume, and EXTERNAL exposure (shared-externally events) — then prints a simple ranked view (prevalence x external exposure) to prioritise which categories/locations to enforce first. Read-only — queries Search-UnifiedAuditLog only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Report.ps1 -Days 21 -CsvPath .\DLPASSESS-Movement.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled (Req 2.3). .EXAMPLE .\DLPASSESS-Report.ps1 -Days 14 Prints movement + a ranked exposure view for the last 14 days. .EXAMPLE .\DLPASSESS-Report.ps1 -Days 30 -CsvPath .\DLPASSESS-Movement.csv Same over 30 days and exports the per-event movement CSV. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only reporting from the unified audit log; no changes. EXPECTED RESULTS: matches by SIT/workload/exposure and a ranked category list. PASS gate: a defensible ranking feeding 'DLP Roadmap - Prioritized - Strategy'. If empty, allow dwell time / confirm the simulation baseline is live and audit logging is on. > [CmdletBinding()] param([int]$Days = 21, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Report.ps1 -Days 21 -CsvPath .\DLPASSESS-Movement.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled (Req 2.3). .EXAMPLE .\DLPASSESS-Report.ps1 -Days 14 Prints movement + a ranked exposure view for the last 14 days. .EXAMPLE .\DLPASSESS-Report.ps1 -Days 30 -CsvPath .\DLPASSESS-Movement.csv Same over 30 days and exports the per-event movement CSV. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only reporting from the unified audit log; no changes. EXPECTED RESULTS: matches by SIT/workload/exposure and a ranked category list. PASS gate: a defensible ranking feeding 'DLP Roadmap - Prioritized - Strategy'. If empty, allow dwell time / confirm the simulation baseline is live and audit logging is on. > [CmdletBinding()] param([int]$Days = 21, [string]$CsvPath, [string]$UserPrincipalName)

DLPASSESS-Validation.ps1

Purpose: Confirms the assessment can run and that it is not accidentally enforcing anything. Checks: unified audit logging is ON (movement data depends on it), Content Explorer / the export cmdlet is reachable (the data map depends on it), the DLP cmdlets are available (roles), and that no DLP policy is in ENFORCE mode unexpectedly. Read-only — makes no changes. Prints a PASS/REVIEW verdict per check. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Validation.ps1 Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPASSESS-Validation.ps1 -ExpectedSimulationPolicy 'DLP Baseline - All Locations - Simulation' Also verifies the named monitor-only baseline exists and is in simulation mode. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only. EXPECTED RESULTS: a checklist with PASS or REVIEW per item. PASS gate for the assessment: audit ON, Content Explorer reachable, roles present, and no unintended enforcement. > [CmdletBinding()] param([string]$ExpectedSimulationPolicy, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPASSESS-Validation.ps1 Requires Security & Compliance PowerShell (Connect-IPPSSession). .EXAMPLE .\DLPASSESS-Validation.ps1 -ExpectedSimulationPolicy 'DLP Baseline - All Locations - Simulation' Also verifies the named monitor-only baseline exists and is in simulation mode. .NOTES Purview — Enterprise DLP Assessment & Strategy. Read-only. EXPECTED RESULTS: a checklist with PASS or REVIEW per item. PASS gate for the assessment: audit ON, Content Explorer reachable, roles present, and no unintended enforcement. > [CmdletBinding()] param([string]$ExpectedSimulationPolicy, [string]$UserPrincipalName)